

GUÍA METODOLÓGICA DETALLADA

Cálculo de Índice de Madurez Cibernética (IGM), Análisis e Interpretación

Versión: 2.0 | Fecha: Enero 2026 | Aplicable a: Todas las organizaciones

1. INTRODUCCIÓN A LA METODOLOGÍA

Esta guía describe el proceso sistemático para convertir respuestas de encuesta en métricas cuantificables de madurez cibernética, permitiendo a las organizaciones:

1. Establecer línea base actual de ciberseguridad
2. Identificar brechas vs. target/benchmarks
3. Priorizar inversiones mediante análisis ROI
4. Monitorear progreso a lo largo del tiempo

2. FRAMEWORK CONCEPTUAL: NIST CSF + ACET + GQM

2.1 Capas de la Metodología

CAPA 1: Meta Estratégica (GQM Goal)

└ Ejemplo: "Alcanzar madurez nivel 3 en NIST CSF en 18 meses"

CAPA 2: Preguntas Operacionales (GQM Questions)

└ Ejemplo: "¿Qué % de controles NIST están implementados?"
"¿Cuál es el tiempo medio de detección de incidentes?"

CAPA 3: Métricas Cuantitativas (GQM Metrics)

└ Ejemplo: KPI = % Cumplimiento de Controles
KRI = Tiempo Medio Detección (horas)

2.2 Mapeo a Niveles de Madurez ACET

Nivel	Descripción ACET	Rango de Puntuación
Ad Hoc	Sin prácticas formales, actividades inconsistentes	0-20%
Baseline	Procesos iniciales, documentación mínima	21-40%
Evolving	Prácticas documentadas, inconsistencia residual	41-60%
Intermediate	Procesos maduros, medible, repetible	61-80%
Advanced	Optimizado, integrado, mejora continua	81-95%
Innovative	Vanguardia, automatización, predicción	96-100%

3. ESQUEMA DE PUNTUACIÓN

3.1 Asignación de Puntos por Respuesta

Cada pregunta se califica según:

Sí / Implementado completamente	= 100 puntos
Parcialmente / En progreso	= 50 puntos
No / No implementado	= 0 puntos
NA / No Aplica	= Excluida del cálculo
DK / Desconoce	= 25 puntos (penalización por falta de visibilidad)

Ejemplo de Cálculo Simple:

- Pregunta 1: Sí (100 pts) + Pregunta 2: Parcialmente (50 pts) + Pregunta 3: No (0 pts) = 150 pts / 3 preguntas = **50% de cumplimiento**

3.2 Ponderación por Dominio

Mientras que todas las preguntas contribuyen al cálculo, algunos dominios tienen **peso diferenciado** según importancia estratégica:

Dominio	Peso	Justificación
Gobierno (GV)	20%	Anclaje estratégico, requiere énfasis
Identificar (ID)	15%	Visibilidad crítica para otros dominios
Proteger (PR)	25%	Controles defensa más numerosos
Detectar (DE)	15%	Detección oportuna es crítica
Responder (RS)	15%	Velocidad de respuesta minimiza daño
Recuperar (RC)	10%	Resiliencia menos inmediata pero importante

Fórmula IGM ponderado:

$$IGM = (GV \times 0,20) + (ID \times 0,15) + (PR \times 0,25) + (DE \times 0,15) + (RS \times 0,15) + (RC \times 0,10)$$

3.3 Puntuaciones Complementarias

Además del IGM, se generan scores específicos para:

- Análisis de Vulnerabilidades (AV): Promedio de preguntas 7.1 - 7.3
- SIEM Effectiveness Score (SES): Promedio de preguntas 8.1 - 8.4
- Security Awareness Training Score (SATS): Promedio de preguntas 9.1 - 9.4

4. CÁLCULO DEL ÍNDICE DE MADUREZ CIBERNÉTICA (IGM)

4.1 Paso 1: Normalizar Respuestas por Dominio

Para cada dominio NIST CSF, agrupe las preguntas:

Ejemplo: Dominio Gobierno (GV)

- P1.1.1: Respuesta = Sí → 100 pts
- P1.1.2: Respuesta = Parcialmente → 50 pts
- P1.1.3: Respuesta = Sí → 100 pts
- P1.1.4: Respuesta = Parcialmente → 50 pts
- **Subtotal GV** = $(100+50+100+50) / 4 = 75\%$

Repita para cada dominio (ID, PR, DE, RS, RC).

4.2 Paso 2: Aplicar Ponderaciones

$$\begin{aligned} \text{IGM} &= (75 \times 0,20) + (80 \times 0,15) + (70 \times 0,25) + \\ &\quad (65 \times 0,15) + (72 \times 0,15) + (60 \times 0,10) \\ &= 15 + 12 + 17,5 + 9,75 + 10,8 + 6 \\ &= 71,05\% \end{aligned}$$

Este IGM del **71,05%** ubica a la organización en nivel **Advanced** (80+ sería Innovative).

4.3 Paso 3: Asignar Nivel de Madurez

Basándose en el IGM resultante:

IGM: 0-20% → Ad Hoc (No formalizado)
 IGM: 21-40% → Baseline (Iniciado)
 IGM: 41-60% → Evolving (En desarrollo)
 IGM: 61-80% → Intermediate (Maduro)
 IGM: 81-95% → Advanced (Optimizado)
 IGM: 96-100% → Innovative (Vanguardia)

En el ejemplo: IGM 71% = Nivel Intermediate

5. ANÁLISIS COMPARATIVO Y BENCHMARKING

5.1 Comparación Intra-Organizacional (Radar Chart)

Propósito: Identificar dominios débiles vs. fuertes

Dominio	Puntuación	Benchm. Sector	Gap
GV	75%	78%	-3%
ID	80%	82%	-2%
PR	70%	75%	-5% ← Prioridad
DE	65%	70%	-5% ← Prioridad
RS	72%	71%	+1%
RC	60%	68%	-8% ← Máxima Prioridad

5.2 Benchmarking Territorial

Comparar IGM de la organización vs. promedio nacional/sectorial:

- Promedio Nacional España (2025): 64%
- Promedio Sector Financiero: 76%
- Promedio Sector Sanitario: 58%
- Promedio Grandes Empresas: 72%
- Promedio PyMEs: 52%

Interpretación:

- Si IGM > Benchmark sectorial: organización **arriba del promedio**
- Si IGM < Benchmark sectorial: requiere **acción prioritaria**

6. ANÁLISIS DE BRECHAS (GAP ANALYSIS)

6.1 Identificación de Brechas Críticas

Paso 1: Definir Target State

Organización define su objetivo de madurez por dominio, típicamente:

- Pequeña empresa: Target = Evolving (50%) en Identificar, Proteger, Detectar
- Mediana empresa: Target = Intermediate (70%) en todos los dominios
- Grandes empresas: Target = Advanced (85%) en dominios críticos

Paso 2: Calcular Brechas

Gap = Target Score - Current Score

Ejemplo:

Dominio PR:

Target = 80% (Intermediate)

Current = 70%

Gap = 10 puntos porcentuales

Paso 3: Priorizar por Impacto y Esfuerzo

Dominio	Current	Target	Gap	Criticidad	Esfuerzo	Prioridad
PR	70%	80%	10%	Alta	Medio	1
RC	60%	75%	15%	Media	Alto	2
DE	65%	80%	15%	Alta	Alto	3
GV	75%	85%	10%	Alta	Bajo	4

7. CÁLCULO DE RETORNO DE INVERSIÓN (ROI) EN CIBERSEGURIDAD

7.1 Metodología FAIR para ROI

Fórmula:

Risk Reduction Value = (Original Risk × Risk Reduction %) - (Implementation Cost)
ROI % = (Risk Reduction Value / Implementation Cost) × 100

7.2 Ejemplo Práctico: Implementación MFA

Datos de Entrada:

1. RIESGO ORIGINAL (Sin MFA)
 - Probabilidad de compromiso credencial: 25% anual (ARO)
 - Coste promedio por incidente: €300.000 (SLE)
 - Riesgo inherente = 25% × €300.000 = €75.000 anuales
2. RIESGO RESIDUAL (Con MFA)
 - Probabilidad reducida a: 5% (ARO)
 - Coste = 5% × €300.000 = €15.000 anuales
 - Reducción de riesgo = €75.000 - €15.000 = €60.000
3. COSTE DE IMPLEMENTACIÓN
 - Herramienta MFA: €40.000 (setup + 3 años)
 - Capacitación: €5.000
 - Total Inversión: €45.000
4. CÁLCULO ROI

ROI = (€60.000 - €45.000) / €45.000 × 100 = 33% ROI

Payback Period = €45.000 / €60.000 = 0,75 años (9 meses)

7.3 Matriz ROI por Dominio

Se pueden calcular ROIs para cada dominio/control:

Control	Inversión	Beneficio Anual	ROI	Payback
MFA	€45K	€60K	33%	9 meses
EDR	€120K	€200K	67%	7 meses
SIEM	€150K	€180K	20%	10 meses
Capacitación	€30K	€90K	200%	4 meses

8. INDICADORES CLAVE DE RIESGO (KRIs) Y CLAVE DE DESEMPEÑO (KPIs)

8.1 KRIs: Indicadores de Riesgo Cibernético

Estos indicadores **anticipan problemas** de seguridad:

KRI	Definición	Umbral Crítico	Acción
% CVE Sin Parchear	% vulnerabilidades críticas abiertas >30 días	>5%	Escalación CISO
Phish Click Rate	% empleados que cae en phishing simulado	>20%	Capacitación adicional
Cobertura SIEM	% sistemas con logs en SIEM	<80%	Expansión infra
Acceso No Autorizado	# intentos compromiso identidad/mes	>100	Investigación
Controles No Evaluados	% controles NIST sin evidencia reciente	>10%	Re-auditoría

8.2 KPIs: Indicadores de Desempeño

Estos indicadores **miden efectividad** de defensas:

KPI	Definición	Target	Fórmula
MTTD	Tiempo medio para detectar incidente	<2 horas	Total tiempo / # incidentes
MTTR	Tiempo medio para resolver incidente	<4 horas	Total tiempo / # resueltos
Cobertura Audit	% sistemas auditados anualmente	>90%	Assets auditados / Total
Compliance Score	% requisitos regulatorios cumplidos	>95%	Req. cumplidas / Total
Training Completion	% empleados con capacitación al día	>95%	Completados / Total

9. ANÁLISIS DE TENDENCIAS (TEMPORAL)

9.1 Seguimiento Longitudinal del IGM

Graficar IGM cada trimestre para visualizar progreso:

Trimestre	IGM	Cambio	Tendencia
Q4 2024	58%	Base	—
Q1 2025	61%	+3%	↗
Q2 2025	64%	+3%	↗
Q3 2025	68%	+4%	↗
Q4 2025	71%	+3%	↗

Interpretación: Tendencia positiva consistente indica mejora sostenida.

9.2 Análisis de Velocidad de Mejora

Velocidad Mejora = (IGM Final - IGM Inicial) / Meses Transcurridos

Ejemplo: (71% - 58%) / 12 meses = 1,08% mejora/mes

Meta típica: 1-2% mejora mensual (12-24% anual)

10. CÁLCULO DE ÍNDICES COMPLEMENTARIOS

10.1 Vulnerability Assessment Score (VAS)

Promedio ponderado de preguntas 7.1-7.3:

$$\text{VAS} = (\text{Gestión Vulnerabilidades} \times 0,4) + (\text{Pentests} \times 0,4) + (\text{Gestión Configuración} \times 0,2)$$

Interpretación:

- VAS >80%: Programa maduro, riesgos identificados regularmente
- VAS 60-80%: Programa básico, cobertura incompleta
- VAS <60%: Vulnerabilidades probablemente desconocidas

10.2 SIEM Effectiveness Score (SES)

Promedio ponderado de preguntas 8.1-8.4:

$$\text{SES} = (\text{Infraestructura} \times 0,25) + (\text{Correlación/Detección} \times 0,35) + (\text{Workflows} \times 0,20) + (\text{KPIs} \times 0,20)$$

Interpretación:

- SES >80%: SIEM como pilar de SOC maduro
- SES 60-80%: Funcionalidad básica, mejoras necesarias
- SES <60%: SIEM subutilizado, considerar rechazar o reestructurar

10.3 Security Awareness Training Score (SATS)

Promedio ponderado de preguntas 9.1-9.4:

$$\text{SATS} = (\text{Programa General} \times 0,25) + (\text{Indicadores Efectividad} \times 0,35) + (\text{Especialización} \times 0,25) + (\text{Madurez} \times 0,15)$$

Interpretación:

- SATS >80%: Cultura de seguridad embebida, empleados son defensores
- SATS 60-80%: Concienciación presente pero inconsistente
- SATS <60%: Capacitación superficial, riesgo humano alto

11. REPORTERÍA Y VISUALIZACIONES

11.1 Dashboard Ejecutivo

Incluir:

1. **IGM actual vs. Target** (gauge chart)
2. **Dominio NIST (radar chart)** con benchmark sectorial
3. **Tendencia temporal** (línea)
4. **KPIs clave** (scorecards)
5. **Matriz Prioridad** (riesgos vs. esfuerzo)

11.2 Tabla de Recomendaciones Priorizado

Rank	Tema	Acción	Inversión	ROI	Plazo	Propietario
1	IAM	Impl. MFA	€45K	33%	3 m	IT Manager
2	Entrenamiento	Capacitación phishing	€30K	200%	2 m	CISO
3	SIEM	Expandir cobertura	€120K	67%	6 m	SOC Lead
4	Gobernanza	Política revisada	€5K	Cumplimiento	1 m	CISO

12. INTERPRETACIÓN DE RESULTADOS SEGÚN CONTEXTO

12.1 Por Tamaño Organizacional

PyMEs (<250 empleados):

- Benchm. Realista: 50-65% IGM
- Enfoque: Baselines (Gobierno, Proteger, Detectar)
- Horizonte: 18-24 meses

Medianas (250-1.000):

- Benchm. Realista: 65-75% IGM
- Enfoque: Maduración integral
- Horizonte: 24-36 meses

Grandes (>1.000):

- Benchm. Realista: 75-85%+ IGM
- Enfoque: Advanced/Innovative, automatización
- Horizonte: 36+ meses

12.2 Por Sector

- Financiero: Target 85%+, regulación estricta (GDPR, NIS2)
- Sanitario: Target 80%+, vida humana en juego
- Industria: Target 75%+, protección OT/ICS
- Retail: Target 70%+, volumen de datos

13. VALIDACIÓN DE DATOS Y CONFIABILIDAD

13.1 Criterios de Confiabilidad de Encuesta

La encuesta es válida si:

5. ✓ Respondidas $\geq 80\%$ de preguntas (excluidas NA)
6. ✓ Menos de 10% preguntas en "DK"
7. ✓ Consistencia interna: correlación entre preguntas relacionadas
8. ✓ Validación técnica: respuestas confirmadas con auditoría/escaneo

13.2 Ajustes por Falta de Evidencia

Si hay muchas respuestas "DK", ajustar IGM penalizando 25 puntos por cada DK no validada.

14. CASOS DE USO Y EJEMPLOS

14.1 Caso PyME Retail

Current State:

- IGM: 52% (Evolving)
- Dominios débiles: GV (40%), RC (35%)
- SATS: 45% (capacitación insuficiente)

Target: 65% en 18 meses

Roadmap Q1-Q4:

- Q1: Política CISO, capacitación anual
- Q2: SIEM básico, escaneo vulnerabilidades
- Q3: Backups automatizados, incident response
- Q4: Revisión anual, roadmap 2027

Inversión estimada: €80K

ROI esperado: Evitar breach potencial €500K = 525% ROI

14.2 Caso Industria Energética (Crítica)

Current State:

- IGM: 71% (Intermediate)
- NIS2 compliance: 80%
- OT/ICS coverage: 60% (brecha)

Target: 85% + OT full coverage en 24 meses

Prioridades:

1. OT segmentation + monitoring (€300K, 6 meses)
2. Threat intelligence compartida (€50K)
3. Red team exercises trimestrales
4. Capacitación especializada OT/SCADA (€80K)

Total inversión: €430K

ROI: Mitigación riesgo sabotaje + cumplimiento = ~€2M beneficio potencial

Esta guía facilita la cuantificación rigurosa de madurez cibernética, permitiendo decisiones de inversión basadas en datos.